

QUESTIONARIO DE AVALIACAO DE SEGURANCA

Due Diligence de Fornecedores TIC . Art. 21.o §2(d) NIS2 . Versao 1.0

Instrucoes: Preencha os campos amarelos. Assinale Sim/Nao. Documente evidencias na coluna respectiva.
Enviar ao fornecedor com prazo de 20 dias uteis. Arquivar: /NIS2/Fornecedores/[Nome]/DueDiligence_[Ano].pdf

IDENTIFICACAO

Empresa avaliada:

Servico/Produto:

Pessoa responsavel:

Email de resposta:

1. GOVERNANCA E ORGANIZACAO DE SEGURANCA				
Pergunta	Sim	Nao	N/A	Evidencia / Comentario
Existe um Responsavel de Seguranca (CISO ou equivalente) formalmente nomeado?	☐	☐	☐	
A empresa tem uma Politica de Seguranca da Informacao (PSI) documentada e aprovada pela gestao?	☐	☐	☐	
A empresa possui certificacao ISO 27001 ou SOC 2 Type II? (Se sim, incluir copia do certificado valido)	☐	☐	☐	
A empresa realiza analises de risco de ciberseguranca pelo menos anualmente?	☐	☐	☐	
A empresa tem um Plano de Resposta a Incidentes (IRP) documentado e testado?	☐	☐	☐	
2. CONTROLO DE ACESSOS E IDENTIDADES				
Pergunta	Sim	Nao	N/A	Evidencia / Comentario
O MFA (autenticacao multifactor) e obrigatorio para TODOS os colaboradores com acesso a sistemas que suportam o servico prestado?	☐	☐	☐	
O principio do menor privilegio e aplicado — cada colaborador tem apenas os acessos necessarios a sua funcao?	☐	☐	☐	
Sao realizadas revisoes periodicas de acessos (minimo trimestral) para remover acessos desnecessarios?	☐	☐	☐	

Os acessos de ex-colaboradores sao revogados no prazo de 2 horas apos saida da empresa?	☐	☐	☐	
Os acessos remotos de tecnicos de manutencao sao registados em logs com timestamps?	☐	☐	☐	

3. GESTAO DE VULNERABILIDADES E PATCHES

Pergunta	Sim	Nao	N/A	Evidencia / Comentario
Sao realizados scans de vulnerabilidades nos sistemas que suportam o servico contratado, com frequencia minima trimestral?	☐	☐	☐	
Patches criticos (CVSS >= 9.0) sao aplicados no prazo maximo de 48 horas apos publicacao?	☐	☐	☐	
Sao realizados testes de intrusao (pentest) pelo menos anualmente por terceiro independente?	☐	☐	☐	
Existe um processo formal de gestao de vulnerabilidades com priorizacao por criticidade?	☐	☐	☐	

4. PROTECCAO DE DADOS E ENCRIPTACAO

Pergunta	Sim	Nao	N/A	Evidencia / Comentario
Todos os dados dos clientes sao encriptados em repouso (AES-256 ou equivalente)?	☐	☐	☐	
Todas as comunicacoes com dados dos clientes usam TLS 1.2 ou superior?	☐	☐	☐	
Sao realizados backups dos dados dos clientes com frequencia minima diaria?	☐	☐	☐	
Os backups sao testados regularmente (restauro completo testado, minimo trimestral)?	☐	☐	☐	
Os backups estao geograficamente separados dos dados de producao (regra 3-2-1 ou equivalente)?	☐	☐	☐	

5. NOTIFICACAO DE INCIDENTES E RESPOSTA

Pergunta	Sim	Nao	N/A	Evidencia / Comentario
A empresa compromete-se a notificar o cliente de qualquer incidente no prazo maximo de 24 horas apos deteccao?	☐	☐	☐	

Existe um processo formal de gestao de incidentes com papeis e responsabilidades definidos?	☐	☐	☐	
A empresa tem seguro de ciberrisco activo com cobertura de responsabilidade perante clientes?	☐	☐	☐	
A empresa cumpre o RGPD e tem um DPO (ou equivalente) designado para dados de clientes?	☐	☐	☐	
Em caso de violacao de dados, a empresa notifica o cliente antes de notificar as autoridades (CNPD)?	☐	☐	☐	

6. SUBFORNECEDORES E PORTABILIDADE

Pergunta	Sim	Nao	N/A	Evidencia / Comentario
A empresa consegue listar todos os subfornecedores que tem acesso aos dados ou sistemas do cliente?	☐	☐	☐	
Os contratos com subfornecedores criticos incluem clausulas de seguranca equivalentes as exigidas ao Fornecedor?	☐	☐	☐	
Em caso de cessacao do contrato, os dados do cliente podem ser exportados em formato standard no prazo de 30 dias?	☐	☐	☐	
Apos exportacao confirmada, os dados do cliente sao eliminados definitivamente com emissao de certificado?	☐	☐	☐	

DECLARACAO DO FORNECEDOR

Declaro que as respostas acima sao verdadeiras e completas. Comprometo-me a notificar o Cliente de qualquer alteracao.

Nome:

Cargo:

Data: